

INTRUSION TESTING COURSE — 420-B06-VA

Malware Case Study Analysis

Pegasus Spyware (NSO Group)

Prepared by: Marco Helie

AEC Cybersecurity Prevention and Intervention

Collège Vanier – Continuing Education

September 14, 2026

Executive Summary

This report presents a structured case study of Pegasus, the commercial "mercenary" spyware developed by the Israeli firm NSO Group, prepared for the Intrusion Testing course. It covers the malware's scope and functionality, its technical architecture and infection chain, indicators of compromise, its mapping to the MITRE ATT&CK framework, the specific vulnerabilities it has exploited, and the defensive controls that would have prevented or limited its impact. Technical details — including exploit-chain CVEs, CVSS scores, device artifacts, and command-and-control infrastructure — were verified against primary and vendor threat-intelligence sources (Citizen Lab, Amnesty International Security Lab, Lookout, Google Project Zero, NVD, MITRE ATT&CK, and U.S. court records) rather than taken at face value, and are cited in the References section.

1. Overview of the Attack

Name of the Malware	Pegasus (the Android variant is tracked separately as "Chrysaor"); developed by NSO Group, an Israeli cyber-intelligence company founded in 2010
Year	Active since at least 2016 — first publicly exposed in August 2016; major documented waves in 2019 (WhatsApp), 2020–2021 (KISMET, FORCEDENTRY), and 2023 (BLASTPASS); still active
Region(s)	Global — Citizen Lab identified suspected NSO operators in 45 countries (2018); confirmed infections span Mexico, the UAE, Saudi Arabia, India, Hungary, Poland, Spain, Morocco, Bahrain, El Salvador, Rwanda, and many others
Targeted Industries / Organizations	Not industry-focused — Pegasus targets individuals: journalists, human rights defenders, lawyers, political opposition figures, diplomats, and heads of state. A 2021 leaked list contained more than 50,000 phone numbers of potential targets, including 3 presidents, 10 prime ministers, and a king

Pegasus was first exposed in August 2016, when Emirati human rights defender Ahmed Mansoor received suspicious SMS links and forwarded them to Citizen Lab, which — together with Lookout — uncovered a fully weaponized iOS zero-day chain ("Trident") and triggered an emergency Apple patch (iOS 9.3.5). A decade later, Pegasus remains the reference example of commercial zero-click spyware: software sold to government agencies that can compromise a fully patched smartphone with no interaction from the victim whatsoever, and silently convert it into a 24/7 surveillance device.

2. Type and Functionality

Malware Type

Pegasus is best classified as **mercenary spyware** (also called surveillanceware or a commercial mobile implant). Unlike ransomware or worms, its purpose is neither extortion nor propagation: it is built for covert, long-term surveillance of a specific individual. NSO Group licenses it to government intelligence and law-enforcement

clients, who select the targets — a business model that has made "mercenary spyware" a distinct category in modern threat analysis.

Technical Operation

- **Zero-click infection:** modern Pegasus requires no victim interaction. Exploits are delivered through iMessage (FORCEDENTRY, KISMET), WhatsApp voice calls (CVE-2019-3568), and malicious PassKit/ImageIO attachments (BLASTPASS) — the payload executes simply because the device receives and parses the message.
- **One-click infection:** earlier versions (2016) relied on spear-phishing SMS messages containing a malicious link; a single tap silently jailbroke the device through a Safari/WebKit exploit.
- **Full device surveillance:** reads SMS, email, and — critically — end-to-end encrypted messages (WhatsApp, Signal, Telegram) by reading them at the endpoint after decryption; records calls; covertly activates the microphone and camera; tracks GPS location in real time; exfiltrates photos, contacts, call logs, and browsing history.
- **Credential and token theft:** extracts keychain contents, saved passwords, and cloud-service authentication tokens, enabling access to accounts beyond the device itself.
- **Covert exfiltration:** collected data is batched and sent over HTTPS to an anonymized command-and-control network, typically when the device is on Wi-Fi to avoid notice; SMS can serve as a fallback channel.

Spread / Infection Method

Pegasus does **not** spread. It has no worm or self-propagation component: every infection is an individual, deliberate operation by an NSO customer against a chosen phone number or device. This is the opposite of opportunistic malware such as WannaCry — Pegasus infections are, by design, precisely targeted.

3. Impact and Consequences

Damage Caused

Category	Impact
Privacy / Security	Total compromise of the victim's digital life. End-to-end encryption is not broken but bypassed at the endpoint, so no messaging app — however secure — protects a compromised device. Journalists' confidential sources, lawyers' privileged communications, and activists' networks were exposed.
Human Safety	Forensic analyses linked Pegasus infections to grave real-world harm: the phone of Jamal Khashoggi's fiancée, Hatice Cengiz, was infected days after his October 2018 murder; Mexican journalist Cecilio Pineda Birto was targeted before being murdered in 2017; UAE activist Ahmed Mansoor — the 2016 target who exposed Pegasus — was later imprisoned for ten years.
Scale	Roughly 1,400 WhatsApp users were targeted in April–May 2019 alone (per U.S. court records); 36 Al Jazeera journalists were attacked in 2020; 11 U.S. State Department officials were infected in 2021; a 2021 leaked list contained 50,000+ phone numbers of potential targets worldwide, including sitting heads of state such as French President Emmanuel Macron.

Reputational / Political	Pegasus became the defining scandal of the commercial spyware industry, triggering parliamentary inquiries (the EU's PEGA committee), diplomatic incidents (Spain, France, India, Poland, Hungary), and sustained scrutiny of surveillance-technology export controls.
---------------------------------	--

Who Was Affected

- **Journalists and media organizations** — Al Jazeera (36 staff, 2020), El Faro in El Salvador (22 staff, 2022), and reporters in Mexico, India, Hungary, and elsewhere.
- **Human rights defenders and lawyers** — Ahmed Mansoor (UAE), Omar Abdulaziz (Canada), Loujain al-Hathloul's circle (Saudi Arabia), and activists across Bahrain, Morocco, Rwanda, and Togo.
- **Politicians and officials** — Polish opposition senator Krzysztof Brejza; Spanish Prime Minister Pedro Sánchez and Defence Minister Margarita Robles (devices infected 2021, disclosed 2022); Catalan independence figures; Indian opposition figures; numbers belonging to 14 heads of state and government on the 2021 list.
- **Executives** — Amazon founder Jeff Bezos: a forensic analysis by FTI Consulting concluded his phone was compromised in 2018 by a malicious video file sent from the Saudi crown prince's WhatsApp account; UN special rapporteurs assessed Pegasus as the likely tool.

Response and Fallout

- **U.S. sanctions:** in November 2021, the U.S. Department of Commerce added NSO Group (and Candiru) to the Entity List for activities contrary to U.S. national security and foreign policy interests, severely restricting its access to U.S. technology.
- **Litigation:** WhatsApp/Meta sued NSO in October 2019; the court granted summary judgment for WhatsApp in December 2024, and in May 2025 a federal jury ordered NSO to pay \$167,254,000 in punitive damages plus \$444,719 in compensatory damages — the first U.S. jury verdict against a commercial spyware vendor. A permanent injunction followed; the case is on appeal. Apple filed its own lawsuit against NSO in November 2021.
- **Vendor countermeasures:** Apple shipped emergency patches (iOS 9.3.5 in 2016; iOS 14.8 in 2021; iOS 16.6.1 in 2023), introduced threat notifications to warn targeted users, and launched Lockdown Mode (2022) — which Citizen Lab later observed blocking NSO zero-click chains in the wild.
- **Policy changes:** the EU Parliament's PEGA inquiry (2022–2023) documented abuses in member states; Israel tightened export-license oversight; NSO entered sustained financial and ownership turmoil.

4. Method of Infection

Entry Point: Pegasus reaches devices through two delivery models. The modern model is **zero-click**: exploits delivered through services that parse data automatically — iMessage (FORCEDENTRY via a malicious PDF disguised as a GIF; KISMET in 2020), WhatsApp voice calls (specially crafted RTCP packets, with the malicious call sometimes silently removed from the call log), and PassKit attachments (BLASTPASS). The victim does nothing at all. The original 2016 model was **one-click**: a spear-phishing SMS with a link that, once opened, exploited WebKit and jailbroke the phone.

Vulnerability Exploited: Pegasus is not tied to a single vulnerability — NSO maintains a pipeline of zero-day chains. Documented examples include the Trident chain (CVE-2016-4655 / -4656 / -4657, 2016), the WhatsApp VOIP stack buffer overflow (CVE-2019-3568, 2019), the FORCEDENTRY iMessage exploit (CVE-2021-30860, 2021), and the BLASTPASS chain (CVE-2023-41064 chained with CVE-2023-41061, 2023). Full technical detail, including CVSS scoring, is provided in Section 9.

Targeted vs. Random Attack: Pegasus is among the most deliberately targeted malware in existence. Each infection is an individual operation conducted by a government client against a selected person — the antithesis of indiscriminate outbreaks. The 50,000-number list documented by the Pegasus Project represents numbers individually selected by NSO customers as candidates for surveillance.

5. Architecture

Components

Component		Purpose
Exploit delivery stage		Zero-click payload (iMessage / WhatsApp / PassKit attachment) or one-click phishing link that triggers the initial vulnerability and achieves code execution inside a sandboxed process (e.g., the iMessage parser or WebKit).
Privilege-escalation stage		Kernel exploit that escapes the sandbox and obtains root privileges, silently jailbreaking the device (e.g., the kernel stage of the Trident chain).
Surveillance agent		The core implant, running under process names that mimic legitimate Apple daemons — documented examples include <i>bh</i> , <i>roleaccountd</i> , <i>stagingd</i> , and <i>msgacntd</i> — to blend into process and network-usage listings.
Hooking / interception modules	/	Inject into messaging and voice applications (WhatsApp, Signal, Skype, Viber, etc.) to read content after decryption, record calls, and activate the microphone and camera.
C2 client		Maintains contact with the operator's infrastructure over HTTPS (with SMS as a fallback channel), receives tasking, and schedules data exfiltration — typically preferring Wi-Fi.
Self-destruct / cleanup module	/	Wipes the implant and its traces if it detects analysis, loses contact with its C2 for an extended period, or receives a removal command — a key anti-forensics feature.

Payload

- Reads SMS, email, call logs, contacts, calendars, browsing history, and application databases — including end-to-end encrypted messengers, read at the endpoint.
- Activates the microphone and camera for room and visual surveillance; tracks GPS location continuously.
- Extracts keychain items, saved passwords, and cloud authentication tokens, extending access beyond the device.
- Monitors device state — network type, battery, installed applications — and disables competing jailbreak software to keep exclusive control.

Command-and-Control (C2) Infrastructure

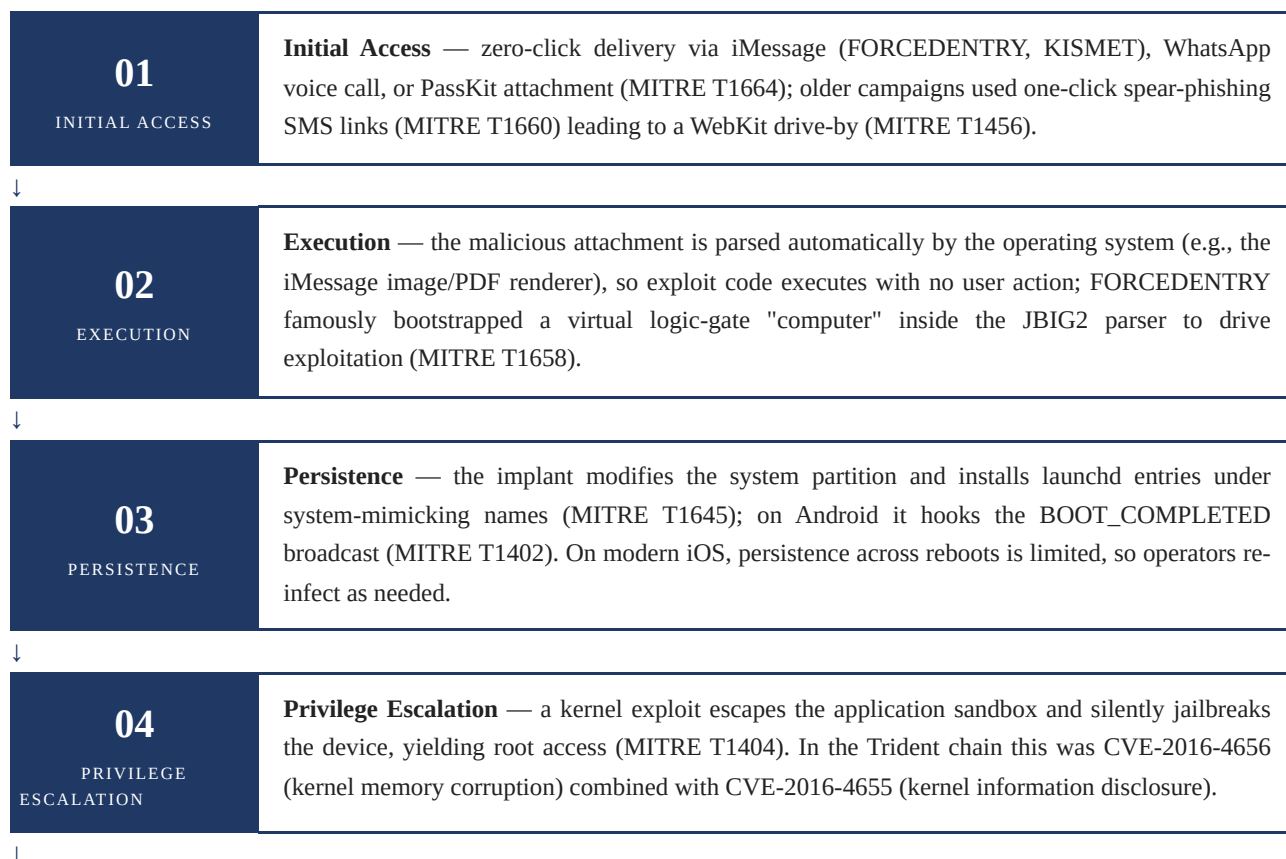
- Multi-tier, anonymized server infrastructure registered through front companies and rotating domain names; Amnesty International has published 700+ Pegasus-related domains across infrastructure generations ("v2" through "v4").
- Communication is encrypted and tunneled over HTTPS; early versions could also receive tasking and exfiltrate via SMS (documented by MITRE as Out-of-Band Data, T1644).
- Zero-click operators additionally control attacker-owned iCloud accounts used to deliver iMessage payloads (see Section 7).

Persistence Mechanisms

- Modifies the device's system partition to maintain persistence (MITRE T1645); on Android, registers for the BOOT_COMPLETED broadcast to reactivate at every boot (MITRE T1402).
- Installs launchd property lists (e.g., *roleaccountd.plist*) under system-mimicking names.
- On later iOS versions the implant often does not survive a reboot — operators compensate by re-infecting targets repeatedly, which is also why Amnesty International recommends that at-risk users restart their phones regularly.

6. Infection Chain

The diagram below traces Pegasus's behavior through each of the nine standard attack-chain stages, cross-referencing the MITRE ATT&CK techniques detailed in Section 8 where applicable.



05 DEFENSE EVASION	Defense Evasion — processes masquerade as legitimate Apple daemons (<i>bh</i> , <i>roleaccountd</i> , <i>stagingd</i>); the implant deletes logs and forensic traces, removes malicious WhatsApp calls from the call log, encrypts C2 traffic, and self-destructs if it detects analysis or prolonged C2 loss.
↓	
06 CREDENTIAL ACCESS	Credential Access — the agent extracts keychain contents, saved passwords, and cloud-service authentication tokens, letting operators reach email and cloud accounts directly. MITRE's S0289 profile assigns no distinct credential-access technique; the behavior is achieved by reading protected on-device stores rather than a separate module.
↓	
07 LATERAL MOVEMENT	Lateral Movement — not used. Pegasus is a single-device implant with no propagation capability: every phone is individually targeted and infected. "Movement" beyond the device happens only indirectly, through stolen cloud tokens and messages.
↓	
08 COMMAND AND CONTROL	Command and Control — encrypted HTTPS sessions to a rotating, anonymized multi-tier server network (700+ documented domains), with SMS as an out-of-band fallback channel (MITRE T1644); exfiltration is scheduled, typically preferring Wi-Fi to avoid detection.
↓	
09 IMPACT	Impact — sustained covert surveillance: audio and camera capture (MITRE T1429, T1512-class), location tracking (T1430), and collection of call logs, contacts, SMS, and application data (T1636.002/.003/.004, T1409). The "impact" is espionage — exposed sources, suppressed dissent, and, in documented cases, physical harm to victims.

7. Indicators of Compromise (IOCs)

The indicators below are drawn from the Amnesty International Security Lab's published Pegasus IOC repository (used by the Mobile Verification Toolkit) and from Citizen Lab / Lookout reporting.

1. Process Names (on-device)

`bh` `roleaccountd` `stagingd` `msgacntd` `frtipd` `gatekeeperd`

Pegasus processes masquerade as legitimate Apple daemons. They appear in forensic artifacts such as *DataUsage.sqlite* (per-process network usage) and *sysdiagnose* logs — the process *bh* has been a reliable indicator since 2016.

2. File Artifacts

`roleaccountd.plist` (launchd persistence entry under a system-mimicking name)

Additional artifacts include staging files in temporary directories, anomalous iMessage/SMS attachment-processing crash logs, and evidence of deleted WhatsApp call records following missed calls (2019 campaign).

3. Attacker-Controlled iCloud Accounts

linakeller2203@gmail.com natalymarinova@proton.me emmadavies8266@gmail.com

Apple IDs registered by operators and used to deliver zero-click iMessage payloads (from Amnesty's published *emails.txt* indicator set); inbound iMessage activity from unknown Apple IDs is itself a warning sign.

4. C2 / Delivery Domains

opposedarrangement.net permalinking.com redirect-connection.com dns-1.co

Examples from the 700+ "v4" infrastructure domains published by Amnesty International (2021). The 2016 one-click campaign sent Ahmed Mansoor links to *sms.webadv.co*. Pegasus domains are typically short-lived, recently registered, and themed around redirects, URLs, and DNS.

5. Network Indicators

- Encrypted HTTPS beaconing from the device to recently registered, otherwise unvisited domains.
- iMessage attachment fetches or lookups from unknown Apple IDs, followed by crashes of message-processing services.
- Unexplained cellular data consumption attributed to unknown processes (visible in *DataUsage.sqlite*).
- SMS messages containing command-like content from unknown senders (fallback C2 channel).

6. Behavioral Indicators

- Evidence of system-partition modification on a non-jailbroken device.
- Apple threat notifications warning of state-sponsored targeting (issued to confirmed victims since 2021).
- Missed WhatsApp calls from unknown numbers that later vanish from the call log.

8. MITRE ATT&CK Mapping

Pegasus is catalogued in the MITRE ATT&CK Mobile matrix as Software **S0289** (Pegasus for iOS) and **S0316** (Pegasus for Android). The table below reproduces MITRE's own documented technique list for S0289 — 15 techniques across 7 tactics — rather than an independently inferred mapping, so that every entry is directly verifiable against the official ATT&CK page.

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1664	Exploitation for Initial Access	Uses zero-day iMessage exploits for initial access.
Initial Access	T1660	Phishing	Distributed via malicious links in SMS messages.

Initial Access	T1456	Drive-By Compromise	Distributed through a website by exploiting Safari vulnerabilities on iOS devices.
Execution	T1658	Exploitation for Client Execution	Can compromise iPhones running iOS 16.6 without any user interaction.
Privilege Escalation	T1404	Exploitation for Privilege Escalation	Exploits iOS vulnerabilities to escalate privileges.
Persistence	T1645	Compromise Client Software Binary	Modifies the system partition to maintain persistence.
Discovery	T1426	System Information Discovery	Monitors the victim for status and disables other jailbreaking software's access to the phone.
Discovery	T1421	System Network Connections Discovery	Monitors connection state and network types, potentially to gauge bandwidth for exfiltration.
Collection	T1429	Audio Capture	Has the ability to record audio.
Collection	T1430	Location Tracking	Updates and sends the location of the phone.
Collection	T1636.002	Protected User Data: Call Log	Captures call logs.
Collection	T1636.003	Protected User Data: Contact List	Gathers contacts by dumping the victim's address book.
Collection	T1636.004	Protected User Data: SMS Messages	Captures SMS messages the victim sends or receives.
Collection	T1409	Stored Application Data	Accesses sensitive data in application files, such as Skype call recordings read from Skype database files.
Command and Control	T1644	Out of Band Data	Uses SMS for command and control.

Notably, MITRE's own profile does not assign Pegasus for iOS a distinct *Credential Access*, *Lateral Movement*, or *Impact* technique — consistent with the analysis in Section 6: credential theft is performed by reading protected on-device stores, there is no lateral movement by design, and the malware's "impact" is the collection itself. The Android profile (S0316) additionally documents *BOOT_COMPLETED* persistence (T1402) and camera capture (T1512).

9. Vulnerability and Attack Vector Analysis

Entry Point: As detailed in Section 4, Pegasus is introduced through zero-click exploitation of messaging and media-parsing services (iMessage, WhatsApp, PassKit/ImageIO) or, historically, one-click SMS phishing links. No credentials, physical access, or user mistakes are required in the zero-click model.

CVE Analysis

CVE ID	CVE-2021-30860
Named Vulnerability	FORCEDENTRY (iMessage zero-click)
Vulnerability Type	Integer overflow (CWE-190) in CoreGraphics JBIG2 PDF processing, leading to arbitrary code execution
CVSS v3.1	7.8 — High (AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)
Affected Systems	iOS < 14.8 and iPadOS < 14.8 (from 13.0), iOS 12.x (< 12.5.5), macOS Big Sur < 11.6, macOS Catalina (< Security Update 2021-005), watchOS < 7.6.2
Patch Available	iOS 14.8 / iPadOS 14.8 / macOS Big Sur 11.6 / Security Update 2021-005 Catalina / watchOS 7.6.2 — released September 13, 2021
Exploitation Status	Captured in the wild by Citizen Lab on a Saudi activist's iPhone; in use since at least February 2021; listed in CISA's Known Exploited Vulnerabilities catalog

Exploitation Details: FORCEDENTRY targets the JBIG2 image codec used by iMessage's automatic PDF/GIF rendering. The integer overflow lets the attacker corrupt memory and — as Google Project Zero's deep dive documented — assemble logical gates from JBIG2 bitmap operations, effectively building a small virtual computer inside the parser that carries out the rest of the exploit. Because iMessage parses attachments automatically, the entire chain runs with zero user interaction, which is why the CVSS vector's "user interaction required" metric (reflecting generic PDF-opening scenarios) understates the real-world delivery: victims never opened anything.

Other Key Vulnerabilities in Pegasus Chains

CVE	Component	CVSS v3.1	Role / Patch
CVE-2016-4657	WebKit (Safari) memory corruption	8.8 — High	Initial RCE of the 2016 Trident one-click chain; patched in iOS 9.3.5 (August 2016). Chained with CVE-2016-4655 (kernel information disclosure) and CVE-2016-4656 (kernel code execution).
CVE-2019-3568	WhatsApp VOIP stack buffer overflow	9.8 — Critical	Zero-click RCE via crafted RTCP packets in a WhatsApp call — the victim need not answer; ~1,400 users targeted (May 2019). Fixed in WhatsApp 2.19.134 (Android) / 2.19.51 (iOS).
CVE-2023-41064	ImageIO buffer overflow	7.8 — High	Malicious image processing in the BLASTPASS zero-click chain, combined with CVE-2023-41061 (Wallet/PassKit); patched in iOS 16.6.1 (September 2023).

Security Weaknesses Exploited

Failed Control	Analysis
----------------	----------

Patch Management	Every documented Pegasus wave was stopped by a patch — yet infections continued on devices running outdated iOS/Android versions. Auto-update adoption and support for older devices directly determine the size of the vulnerable population.
User Awareness	Zero-click delivery makes traditional "don't click suspicious links" advice insufficient: FORCEDENTRY and BLASTPASS victims did nothing wrong. Awareness still matters for one-click variants, but cannot be the primary defense.
Attack Surface / Access Control	Rich messaging services that automatically parse attachments (iMessage, WhatsApp calling, PassKit) provide remote, unauthenticated code paths into the OS. Apple's Lockdown Mode — which blocks most iMessage attachments and wired connections — directly attacks this weakness and has been observed stopping NSO chains.
Endpoint Protection	Mobile platforms restrict traditional antivirus: security apps cannot inspect other processes on iOS, leaving commercial implants largely invisible to on-device defenses.
Monitoring Systems	Organizations typically have no telemetry from employee phones. Without forensic tooling (MVT) or vendor notifications, infections were discovered months or years late — or never.
Procurement / Export Control	Pegasus was sold as a lawful-intercept product with weak end-use controls; governments misused it against civil society. The U.S. Entity List action and export-license scrutiny addressed this governance failure rather than a technical one.

10. Defensive Countermeasures

Preventive Controls

Control	How It Would Have Reduced Impact
Rapid OS / App Patching	Every major Pegasus chain (Trident, WhatsApp, FORCEDENTRY, BLASTPASS) was closed by a vendor update; same-day updating and Apple's Rapid Security Responses shrink the exposure window to days.
Apple Lockdown Mode	Blocks most iMessage attachment types, disables link previews, and restricts FaceTime calls from unknown callers — removing the exact parsers Pegasus exploits; observed by Citizen Lab to block NSO zero-click chains in the wild.
Attack-Surface Reduction	High-risk users can disable iMessage/FaceTime, use a separate device and number for sensitive work, and avoid unnecessary messaging apps — shrinking the set of remotely reachable parsers.
Security Awareness (one-click vectors)	Training to recognize and report unexpected SMS/WhatsApp links still defeats the one-click delivery model used in 2016-style campaigns.
Device Hardening / MDM	Managed-device policies (current OS enforced, no sideloading, minimal apps, strong passcodes) reduce exploitable surface and complicate re-infection.

Detective Controls

Control	How It Would Have Reduced Impact
---------	----------------------------------

Mobile Forensics (MVT)	Amnesty's open-source Mobile Verification Toolkit, fed with the published Pegasus IOCs (process names, domains, iCloud accounts, files), has confirmed hundreds of infections from device backups and sysdiagnose logs.
Vendor Threat Notifications	Apple's state-sponsored-attack notifications alert targeted users directly, enabling rapid response; similar programs exist at Meta/WhatsApp and Google.
Network / DNS Monitoring	Blocking and alerting on the 700+ published Pegasus C2 domains (and on lookups from unknown iMessage Apple IDs) identifies infected devices and blocks exfiltration.
Anomaly Review	Unexplained data usage by unknown processes, message-service crashes, and vanishing call-log entries are detectable warning signs in mobile device management and carrier data.

Corrective Controls

Control	How It Would Have Reduced Impact
Regular Reboots	Because later iOS implants often do not survive a restart, frequent reboots disrupt active infections and force costly re-infection by the operator.
Device Replacement / Reset	For confirmed compromises, Amnesty and Citizen Lab recommend replacing the device (a factory reset is not guaranteed to remove implants that modify the system partition).
Credential Rotation	Changing passwords and revoking cloud tokens from a clean device cuts off the account-level access gained through keychain and token theft.
Expert Incident Response	Reporting to specialist helplines (Access Now's Digital Security Helpline, Citizen Lab, Amnesty Security Lab) provides victims with forensic confirmation and support.
Legal / Policy Remedies	Export controls, Entity List sanctions, and civil litigation (the \$167M WhatsApp verdict) raise the cost of abuse and drive industry-level deterrence.

Conclusion — Key Takeaways

- **Zero-click changes the defense model:** when infection requires no user action, individual vigilance cannot be the last line of defense — platform hardening and patching must carry the load.
- **Encryption is bypassed, not broken:** Pegasus reads Signal and WhatsApp messages after the device decrypts them; endpoint compromise defeats end-to-end encryption without touching the cryptography.
- **Patch velocity and Lockdown Mode work:** every documented chain ended with a vendor patch, and Apple's Lockdown Mode has blocked NSO exploits in the wild — proven, practical defenses for high-risk users.
- **Persistence is a weak point worth exploiting defensively:** regular reboots meaningfully disrupt modern iOS implants.
- **Accountability is slow but real:** a U.S. Entity List designation, parliamentary inquiries, and a \$167 million jury verdict show that the commercial spyware industry can be constrained — while the market it created continues to grow.

References

- MITRE ATT&CK. "Pegasus for iOS — Software S0289" and "Pegasus for Android — Software S0316." attack.mitre.org.
- Citizen Lab (Marczak, B., & Scott-Railton, J.). "The Million Dollar Dissident: NSO Group's iPhone Zero-Days Used Against a UAE Human Rights Defender" (August 2016).
- Lookout. "Technical Analysis of Pegasus Spyware" (August 2016).
- Citizen Lab. "Hide and Seek: Tracking NSO Group's Pegasus Spyware to Operations in 45 Countries" (September 2018).
- Citizen Lab. "The Great iPwn: Journalists Hacked with Suspected NSO Group iMessage 'Zero-Click' Exploit" (December 2020).
- Amnesty International Security Lab. "Forensic Methodology Report: How to Catch NSO Group's Pegasus" (July 2021), and AmnestyTech Pegasus IOC repository (domains, processes, emails, files).
- Forbidden Stories and partners. "The Pegasus Project" (July 2021).
- Citizen Lab. "FORCEDENTRY: NSO Group iMessage Zero-Click Exploit Captured in the Wild" (September 2021).
- Google Project Zero (Beer, I., & Groß, S.). "A Deep Dive into an NSO Zero-Click iMessage Exploit: Remote Code Execution" (December 2021).
- Citizen Lab. "BLASTPASS: NSO Group iPhone Zero-Click, Zero-Day Exploit Captured in the Wild" (September 2023).
- NVD. "CVE-2016-4657," "CVE-2019-3568," "CVE-2021-30860," "CVE-2023-41064" — Detail pages.
- U.S. Department of Commerce. "Commerce Adds NSO Group and Other Foreign Companies to Entity List for Malicious Cyber Activities" (November 2021).
- Apple Inc. "Apple Sues NSO Group to Curb the Abuse of State-Sponsored Spyware" (November 2021).
- *WhatsApp LLC v. NSO Group Technologies Ltd.*, No. 4:19-cv-07123 (N.D. Cal.) — summary judgment (December 20, 2024) and jury verdict (May 6, 2025).